

Project ID:
R26-CS-003

1. Topic (12 words max)

Browser Security Intelligence: A Multilayer Browser Threat Detection Prevention System

2. Research group the project belongs to

IAS - Information Assurance & Security

3. Specialization of the project belongs to

Cyber Security (CS)

4. If a continuation of a previous project:

Project ID	-
Year	-

5. Brief description of the research problem including references (300 words max) – references not included in word count.

Browser Security Intelligence: A Multilayer Browser Threat Detection and Prevention System

Nature and Gravity of the Problem

Web browsers have become the primary target for modern cyber attacks. Malicious browser extensions can silently steal credentials, intercept web requests and inject scripts into every page a user visits. Browser in Browser phishing attacks create pixel perfect fake login popups that trick users into handing over their OAuth credentials. Hidden Command and Control beacon traffic maintains quiet communication between a compromised browser and an attacker's server and blends in with normal browsing. Multi stage attacks leave traces scattered across different browser artifacts like history cookies and stored credentials but these are never examined together.

The core problem is that no single existing tool addresses all of these threats. Extension analyzers like CRXcavator only do static checks. Phishing detectors rely on URL reputation. Network layer tools like RITA cannot see inside the browser. Forensic tools examine artifacts one type at a time. This leaves critical gaps that attackers exploit daily.

Impact of the Problem

Malicious extensions have affected millions of users in real world campaigns. BitB attacks bypass trusted security indicators. Credential theft can result in account takeovers and data breaches. Organizations that fail to detect these threats may break data protection laws. Without a unified system, security teams can only react instead of preventing attacks.

FoC Research Cluster & Industry Verticals

This research fits within the **Information Assurance and Security (IAS)** group. It supports the Cybersecurity and Cloud Computing industry verticals and is valuable for enterprise security teams and organizations where browsers are critical for daily work.

Sustainable Development Goal (SDG) Alignment

- **SDG 9 – Industry, Innovation & Infrastructure:**
Enhances digital infrastructure and cybersecurity for enterprises and organizations.
- **SDG 11 – Sustainable Cities & Communities:**
Supports secure digital services that modern communities depend on.
- **SDG 16 – Peace, Justice & Strong Institutions:**
Improves trust, transparency and security in digital governance systems.

References

- [1] G. Kumar and Sriram Sowmyanarayanan, "Advanced Malware Detecting Chrome Extension Using Machine Learning," *Advanced Malware Detection using Machine Learning Models*, Apr. 2025, Available: https://www.researchgate.net/publication/391218113_Advanced_Malware_Detecting_Chrome_Extension_Using_Machine_Learning
- [2] mr.d0x, "Browser In The Browser (BITB) Attack," mrd0x.com, Mar. 2022. [Online]. Available: <https://mrd0x.com/browser-in-the-browser-phishing-attack/>
- [3] Active Countermeasures, "RITA – Real Intelligence Threat Analytics," 2023. [Online]. Available: <https://www.activecountermeasures.com/free-tools/rita/>
- [4] R. Obsidian Forensics, "Hindsight – Web Artifact Analysis," 2024. [Online]. Available: <https://github.com/obsidianforensics/hindsight>
- [5] J. Lim, Y. Jin, M. Alharthi, X. Zhang, J. Jung, R. Gupta, K. Li, D. Jang and T. Kim, "SOK: On the Analysis of Web Browser Security," *arXiv*, Dec. 2021. Available: <https://arxiv.org/abs/2112.15561>

[6] J. Gardiner, M. Cova and S. Nagaraja, "Command & Control: Understanding, Denying and Detecting," *arXiv*, Aug. 2014. Available: <https://arxiv.org/abs/1408.1136>

[7] R. R. Chand, N. A. Sharma and M. A. Kabir, "Advanced Web Browser Forensics: A Survey of Evidence Sources, Challenges, and Tools," *Digital Investigation*, vol. 35, pp. 85–105, 2020. Available: <https://www.sciencedirect.com/science/article/pii/S1742287620300264>

6. Brief description of Existing Research and Systems (300 words max)

Description of Existing Research and Systems

Many browser security tools exist today but most focus on solving just one piece of the puzzle. When we look at browser extension security tools like **CRXcavator** and **Tarnish** analyse extension code using static analysis. They search for known malicious patterns which works well for obvious threats. The problem is that these tools cannot see what an extension actually does while running. If an attacker uses obfuscation or triggers malicious behaviour only under certain conditions these scanners miss it completely.

Phishing detection systems take a different approach. Most rely on reputation databases like **Google Safe Browsing** or **PhishTank** which maintain lists of known phishing URLs. These are effective at blocking reported sites but struggle with newer techniques like Browser in Browser attacks. These create fake login windows that look exactly like legitimate popups from Google or Microsoft. Since the phishing page might use a clean domain and just render a fake iframe traditional URL based detection fails.

Network monitoring tools like **RITA** and **Zeek** analyse traffic patterns to spot Command and Control communication by looking for beaconing behaviour. The challenge here is visibility. These tools operate at the network level and cannot tell the difference between legitimate user requests and background requests from malicious extensions. Modern C2 channels often hide inside trusted services like Google Docs or Discord making detection nearly impossible.

Browser forensics tools like **Hindsight** extract artifacts after incidents occur pulling out browsing history cookies and download records. The problem is that these tools work on individual artifact types in isolation. Real attacks span multiple artifact types within seconds and current tools miss these connections. What is missing is a unified system that monitors all layers simultaneously and correlates threats in real time. This research fills that gap.

Gaps and Limitations Identified

- No extension analyser combines ML-based static analysis with **dynamic sandbox monitoring**.
- No phishing detector integrates **DOM-based BiTB fingerprinting** and **visual similarity** in real time.
- No C2 beacon detection tool operates **inside the browser** and existing network tools cannot detect **C2 traffic routed through trusted services**.
- No forensic tool performs **temporal correlation across all major browser artifacts** simultaneously.
- There is no unified platform combining **extension analysis, phishing detection, beacon detection and forensic correlation**.

7. Brief description of the solution's nature, including a conceptual diagram (maximum 500 words).

How the Solution Addresses the Gaps Identified

The proposed system directly solves the major limitations found in current research and tools:

1. **Gap: No tool combines static ML classification with live sandboxed dynamic analysis for extensions.**
Solution: Component 1 introduces a two stage pipeline where extensions are first analysed using a trained machine learning model and then executed inside a secure sandbox to observe real behaviour. Both results are combined to improve detection accuracy.
2. **Gap: No phishing detector combines BiTB fingerprinting with visual similarity in real time.**
Solution: Component 2 uses a multi layer approach including reputation checks URL analysis form behaviour inspection visual similarity and DOM based fingerprinting to detect advanced phishing attacks.
3. **Gap: No beacon detector operates inside the browser with user interaction context.**
Solution: Component 3 monitors browser level requests and captures context such as user activity and source extension. These features are used with timing analysis to detect hidden communication.
4. **Gap: No forensic tool correlates artifacts across multiple types within a time window.**
Solution: Component 4 links browser artifacts within a time window to identify attack patterns across different data sources.
5. **Gap: No unified platform covers all major browser threats together.**
Solution: The system integrates all components into one pipeline that detects analyses correlates and responds to threats in real time.

System Perspective of the Solution

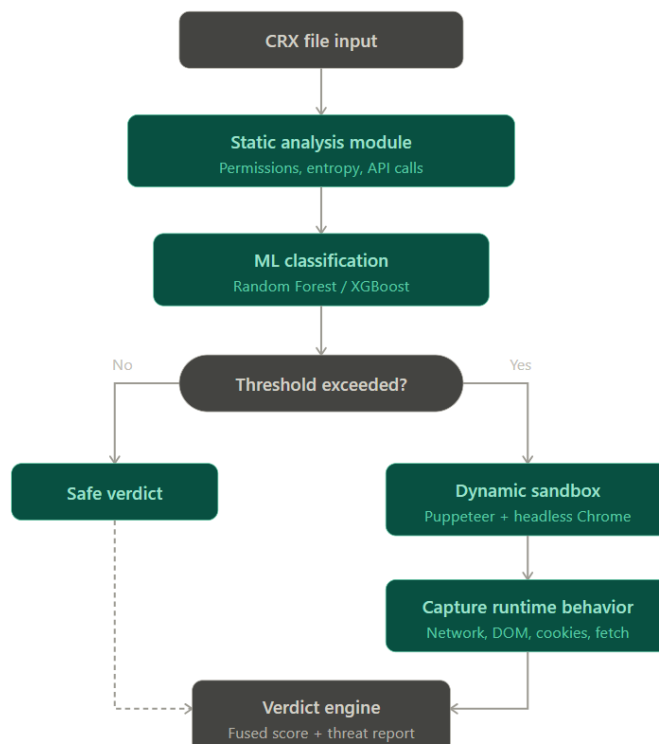
This section describes how the research project functions as a complete system. It follows a clear flow where browser activity is monitored across multiple layers processed through four specialized components and turned into actionable security intelligence.

The system operates through a unified technical stack. At its core a Python FastAPI backend handles all detection logic and data processing. A lightweight Go based desktop agent runs on the user's machine to coordinate between the browser and backend. Inside the browser a TypeScript Manifest V3 extension monitors real time activity without disrupting normal browsing. All findings are visualized through a React dashboard with Tailwind styling while PostgreSQL stores long term forensic data and Redis caches real time threat intelligence. This architecture ensures that the system can watch what extensions do detect phishing attempts track suspicious network patterns and correlate forensic evidence at the same time.

The Four Core Components

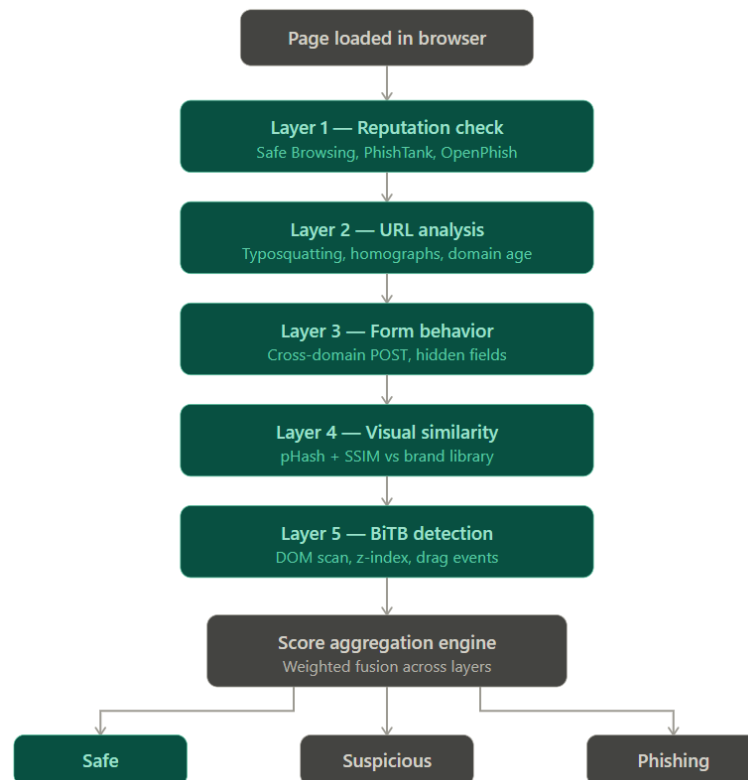
Malicious Browser Extension Analyzer (Component 1)

This component acts as the gatekeeper for browser extensions. When a user installs an extension, the analyzer first runs ML based static analysis on the manifest file and source code. It examines requested permissions API usage patterns and code features to spot red flags. If something looks suspicious the extension is deployed into a Puppeteer controlled headless Chromium sandbox. Inside this isolated environment the system watches what the extension actually does tracking network requests monitoring DOM mutations and recording attempts to access cookies or credentials. Both static analysis and sandbox behavior produce individual risk scores that are fused into a final verdict. This approach detects both obvious malicious code and hidden runtime threats.



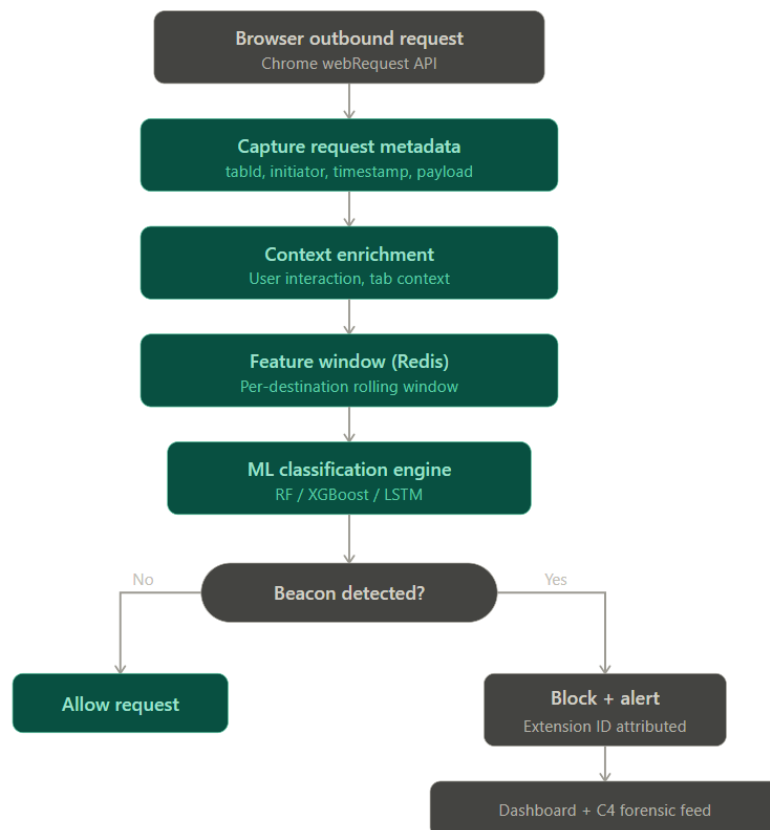
Browser in Browser Phishing Detector (Component 2)

This component is designed to catch visual phishing attacks that traditional URL filters miss. It continuously scans the DOM looking for fake URL bar patterns suspicious CSS z index stacking that creates floating windows iframe origin mismatches and scripts that block normal drag behavior. When these signs appear the detector captures a screenshot of the suspected login window and compares it with legitimate brand pages from Google Microsoft and other targets. Five detection layers contribute to a weighted score. The result is a real time solution that can identify BitB attacks before the user enters credentials.



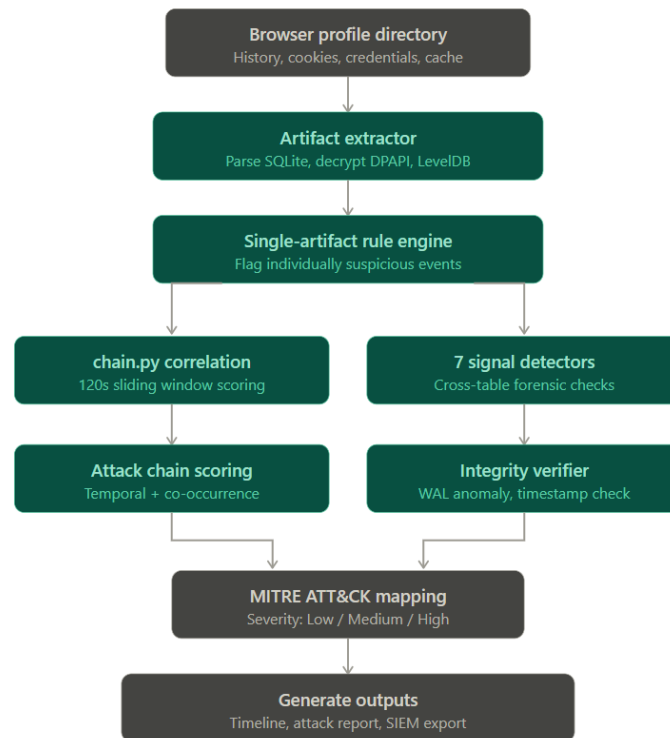
Browser Execution Aware C2 Beacon Detector (Component 3)

Since malicious extensions communicate with Command and Control servers this component tracks every outbound network request with full context. It records which tab made the request which extension triggered it whether the user was active and the timing pattern. A machine learning model analyzes this data to identify beaconing behavior. When detected the request is blocked before transmission and the responsible extension is flagged. This stops hidden communication even when it uses trusted platforms like Google Docs or Discord.



Browser Artifact Forensic Correlation Engine (Component 4)

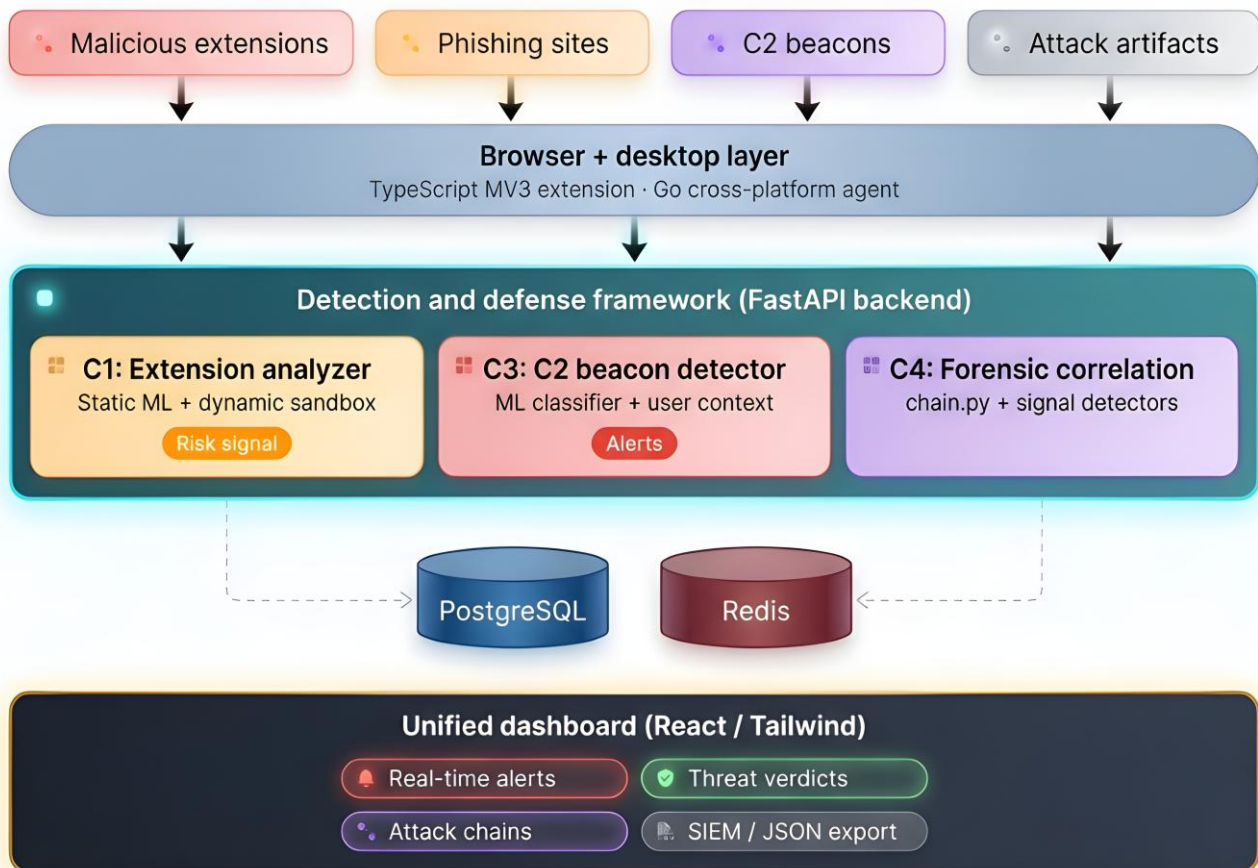
The final component ensures that attacks leave a traceable footprint. It extracts browser artifacts such as history cookies downloads cache entries local storage session data and credentials then normalizes them into a unified timeline. Using sliding window correlation the engine detects suspicious patterns across artifact types. It identifies sequences like credential theft followed by account access or extension installation followed by data exfiltration. SSL verification adds another validation layer. The output is a forensic report mapped to MITRE ATT&CK techniques giving a clear view of the attack flow.



The system delivers comprehensive outputs to security teams. These include real time alerts for extension threats phishing attempts and C2 communication. A unified dashboard shows risk scores blocked threats and forensic timelines. Administrators receive reports that classify threats identify attack sources and provide remediation steps. The MITRE ATT&CK mapping helps teams understand the full attack chain and improve future defenses.

Conceptual Diagram

Browser Security Intelligence's System Architecture



8. Brief overview of the availability of necessary specialized domain expertise, knowledge, and data. (500 words max)

Essential Domain Expertise

This research requires strong knowledge in browser internals extension security phishing techniques network threat detection and digital forensics. The team will focus on key learning areas to build this expertise.

- **Academic Courses and Online Training:** The group will study web security fundamentals browser architecture and Chrome Extension Manifest V3. Courses from platforms such as Coursera and SANS will be used for malware analysis network security and machine learning for cybersecurity. The team will also study browser rendering engines and JavaScript execution environments to understand how browser based attacks work.
- **Industry Accepted Training Resources:** We will follow the MITRE ATT&CK framework for mapping browser based attack techniques and OWASP Browser Security guidelines for secure design principles. Chromium documentation will be used to understand extension APIs and internal browser behaviour. We will also study beacon detection methods from RITA and SANS DFIR materials for forensic analysis.
- **Research Papers and Technical Publications:** The team will review studies on browser extension malware Browser in Browser phishing attacks Command and Control beaconing and cross artifact correlation. Machine learning based detection methods and browser native monitoring approaches will also be studied to stay updated with modern threats.

Through structured learning lab work and supervisor guidance the team will gain both theoretical and practical expertise.

Technical Knowledge and Skills Requirements

The team will develop hands on skills through practical implementation and industry tools in three areas.

- **Practical Labs:** The team will set up isolated environments using Docker and virtual machines for safe testing. We will develop Chrome Manifest V3 extensions and use Puppeteer controlled sandboxes to simulate attack behavior. We will also work with browser forensic artifacts like SQLite databases and LevelDB stores. Machine learning pipelines will be built for classification and detection.
- **Tools and Technologies:** Chrome Extension APIs such as webRequest tabs cookies and storage will be used for monitoring. Python libraries like scikit learn XGBoost and PyTorch will support machine learning development. Puppeteer will be used for sandbox automation. SQLite3 LevelDB and pypykatz will support forensic analysis. The backend will use FastAPI PostgreSQL and Redis for storage and real time processing.

- **Industry Practice:** The team will study tools such as CRXcavator Tarnish RITA Zeek and Hindsight to understand real world limitations. Open source security communities will be followed to stay updated on emerging threats and best practices.

This preparation ensures the team can implement all system components effectively.

Data Requirements

The research uses datasets for training and evaluation across all components collected through safe methods.

- **Extension Datasets:** We will use the Chrome Stats malware corpus with over 7140 malicious extensions along with the chrome mal ids blocklist and benign Chrome Web Store extensions. This supports training for extension classification.
- **Phishing Datasets:** Phishing URLs from PhishTank, OpenPhish and Kaggle datasets will be used. Browser in Browser samples from public repositories will support evaluation of visual detection methods.
- **Beacon Traffic Data:** Synthetic C2 beacon extensions will be created along with benign browsing traffic from lab environments. Additional datasets like malware traffic analysis PCAPs and CICIDS 2017 will help validate detection models.
- **Forensic Profiles:** Simulated attack browser profiles and clean browsing profiles will be created in isolated environments to test correlation accuracy.

All data is collected from controlled or public sources and no real user data is used.

Ethical Clearance Requirements

Ethical clearance is not required as no human participants or personal data are involved. All experiments are conducted in isolated lab environments using synthetic attacks and publicly available datasets. The project follows responsible cybersecurity research practices throughout.

9. Objectives and Novelty

Main Objective To develop a multilayer browser threat detection and prevention system that identifies and stops malicious browser extensions Browser in Browser phishing attacks hidden C2 beacon communications and multi stage attack chains through cross artifact forensic correlation. This research aims to close the gaps between existing security tools that each monitor only one layer of browser activity. To achieve this the project will combine ML based static and dynamic extension analysis for catching hidden malware with a 5 layer phishing detection pipeline that spots fake login windows browser native C2 beacon detection that tracks suspicious network traffic and automated cross artifact correlation that reconstructs complete attack timelines. By bringing these parts together the project provides a complete detect analyze correlate respond solution that no existing tool offers.			
Member Name with Registration No	Sub Objective	Tasks	Novelty
Diwanka K.A.W IT22276414	Malicious Browser Extension Analyzer	• Curate a labelled dataset of malicious and benign browser extensions using Chrome Stats malware corpus chrome mal ids blocklist and Chrome Web Store benign samples. • Build an ML based static analysis pipeline that extracts manifest permissions content script entropy and API call frequency features using Random Forest and XGBoost. • Develop a dynamic sandbox using Puppeteer controlled headless	This component represents the first automated pipeline combining ML based static code classification with live sandboxed dynamic runtime monitoring for browser extensions. Unlike existing tools like CRXcavator and Tarnish that only perform static analysis on extension code this system actually runs suspicious extensions in isolation and watches their real behavior. Even obfuscated or conditionally activated extensions get caught because the sandbox observes genuine Chrome API activity at runtime. The novelty lies in the fusion approach where both static code features and dynamic behavioral signals are combined into a unified threat verdict. No existing tool

		Chromium that monitors outbound network requests DOM mutations cookie access and cross origin fetch attempts. • Fuse static threat scores and dynamic behavioral verdicts into a combined final score with a human readable report.	integrates both stages using a Chrome specific Puppeteer sandbox with a large publicly available labelled dataset for training.
BANDARA K.G.C.R IT22153272	Browser in Browser Phishing Detector	• Implement a Chrome MV3 content script that scans rendered DOM for BitB structural signatures including fake URL bar patterns CSS z index stacking and fixed position popup containers. • Develop form behavior analysis detecting cross domain form submissions hidden credential harvesting fields and suspicious JavaScript that blocks drag operations. • Build a visual similarity module using Puppeteer screenshots with pHash and SSIM comparison against known brand login pages from Google Microsoft and other identity providers. • Design a 5 layer score aggregation engine combining URL reputation domain intelligence form behavior analysis visual	This is the first system combining DOM structural BitB fingerprinting with visual similarity scoring against legitimate identity provider login pages in a unified multi layer pipeline. Most academic research focuses on URL analysis or visual similarity alone but never brings all five detection layers together in one real time browser extension during live browsing. The BitB layer specifically targets fake browser window structural patterns including drag behavior JavaScript and CSS z index manipulation which are detection signals not used in any existing phishing tool. By operating directly inside the browser as a content script the system catches phishing attempts the moment they appear on screen before traditional URL reputation systems can react. This proactive approach stops credential theft at the client side rather than relying on backend blocklists that are always playing catch up.

		similarity scoring and BiTB structural detection.	
Wadduwage L.K IT22208408	Browser Execution Aware C2 Network Detector	- Instrument every outbound browser request via Chrome webRequest API capturing tabId extension initiator timestamp payload size and user interaction state. - Engineer a multi dimensional feature vector per destination combining traditional timing features with novel browser native context signals including time since last user action and extension attribution flag. - Train and compare Random Forest XGBoost and LSTM models on labelled browser traffic datasets containing both benign browsing sessions and synthetic C2 beacon communications. - Implement real time pre transmission blocking at the onBeforeRequest stage with extension level attribution for targeted remediation.	This component introduces three novel dimensions completely unavailable to any existing beacon detection tool. First it operates inside the browser using Chrome webRequest API with full tab context and extension attribution that external network monitoring tools can never see. Second user interaction correlation is the core novel signal no existing tool uses time since last user action as a detection feature. This distinguishes legitimate user triggered requests from automated background beaconing with exceptional accuracy. Third it attributes detected beacons to the exact extension ID enabling targeted remediation instead of blindly blocking all traffic from a domain. By combining browser native visibility with ML based pattern detection this system catches C2 channels hiding inside trusted services like Google Docs or Discord where traditional network tools fail completely.

SANDEEPA S.A.O.D IT22252104	Browser Artifact Forensic Correlation Engine	• Parse all major browser artifact files including history cookies downloads cached credentials local storage and session data then decrypt DPAPI protected credential stores. • Build a sliding window correlation engine that links events across artifact types within 120 second windows and scores them against known multi stage attack patterns. • Implement 7 novel cross table forensic signal detectors that correlate data across separate Chromium SQLite databases and LevelDB stores to identify suspicious relationships invisible to single artifact analysis. • Generate unified timeline reports with MITRE ATT&CK technique mapping severity scoring and JSON export for SIEM integration.	This is the first system performing simultaneous cross artifact temporal correlation across all major browser artifact types in real time. The novelty lies in the combination scoring model where co occurrence of events across different artifacts within a sliding time window produces findings that are completely invisible to single artifact tools like Hindsight. The 7 cross table forensic signal detectors correlate data across separate Chromium databases in ways no existing forensic tool implements for example detecting when a credential is stolen from the password store then that same credential appears in cookies from a different domain followed by file downloads and network exfiltration all within seconds. By normalizing heterogeneous artifact formats into a unified timeline and applying temporal proximity scoring the system reconstructs complete attack chains that span extensions phishing and data theft in one coherent narrative.
---	---	--	---

**10. This part is to be filled by the
Supervisor and the Co-supervisor of the Project.**

- a) This research topic possesses a comprehensive scope suitable for a final-year project.

Yes	☒	No	☐
-----	-------------------------------------	----	--------------------------

- b) The proposed topic exhibits novelty.

Yes	☒	No	☐
-----	-------------------------------------	----	--------------------------

- c) The student group can successfully execute the proposed project.

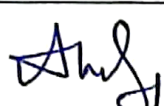
Yes	☒	No	☐
-----	-------------------------------------	----	--------------------------

- d) The proposed sub-objectives reflect the students' areas of specialization.

Yes	☒	No	☐
-----	-------------------------------------	----	--------------------------

- e) Any other comments:

--

	Title	First Name	Last Name	Signature
Supervisor	Ms.	Hansika	Mahadevan	
Co-Supervisor	Mr	Amila	SENARATHNE	
External Supervisor				
Summary of external supervisor's (if any) experience and expertise				